

Authentication Settings

☒ **Login Mode** LDAPOTP (Default)

- LDAP: Require LDAP password only.
- OTP: Require OTP password only.
- LDAPOTP: Require both LDAP and OTP passwords (default).
- DISABLED: Disable OpenOTP.

☒ **OTP Type** TOKEN (Default)

- TOKEN: OATH HOTP/TOTP/OCRA, Yubikey or Mobile OTP Token.
- SMS: SMS one-time password.
- MAIL: Email one-time password.
- LIST: Pre-generated OTP password list.
- PROXY: Forward requests to another RADIUS server.

☐ **OTP Fallback** TOKEN

Fallback OTP Type to be used with SMS or MAIL OTP Types.

☒ **OTP Password Length** 6 (Default)

Note: This setting is ignored for OCRA Tokens as OTP length is part of the OCRA Suite.

☒ **Enable OTP Challenge Mode** Yes (default) ☐ No

You can disable challenged OTP mode if the client application does not support it. Challenge mode is required for OATH/OCRA, SMS and Mail OTP.

☒ **Challenge Session Timeout** 90 (Default)

Timeout to wait for a challenge response (in seconds).
Note: SMS OTP and MAIL OTP may require longer timeouts.

☐ **LDAP Password Protection** Yes (default) ☐ No

Send back an OTP challenge in LDAPOTP even if a wrong LDAP password is entered. This prevents an attacker from knowing if they entered the good LDAP password or not.

☒ **Password Swapping** Yes ☐ No

When enabled, OpenOTP will handle passwords depending on what is expected if only one password is provided in the request, regardless if it is sent as LDAP or OTP.

Blocking Settings

☒ **Failure Blocking Timer** 0

Time to reject new requests for same user after a bad password (in seconds). Set 0 to disable blocking timers.

☒ **Max Failed Passwords** 0

Maximum number of authentication failures before the account is completely blocked. Set 0 to disable blocking.

☒ **Block Time** 0

Time to block a user account after Max Failed Passwords is reached (in seconds). Set 0 to block permanently.

Figure 5: Configuration

```
GRANT ALL ON *.* TO webadm@localhost identified by 'password';
```

Configuring WebADM

Let's then configure WebADM to use our OpenLDAP and MySQL servers. All the configuration files are in `/opt/webadm/conf/`. Edit `server.xml` and change the following, customised according to your set-up:

```
<LdapServer name="LDAP Server"
  host="localhost"
  port="389"
  encryption="NONE"
  cert_file=""
  key_file=""
/>
<SqlServer name="SQL Server"
  type="MySQL"
  host="localhost"
```

Register / Unregister Token

You must register a hardware or software Token before a user can start using it.

Resync Token

Event-based and time-based tokens can get out of sync. You can use the action to resync the Token counter or clock drift.

Change PIN Code

MobileOTP and OCRA Tokens support a PIN code. Use this action to set or reset the PIN code on the server.

Emergency OTP

An emergency OTP is an auto-expirable static OTP which can be used when the user cannot use his usual OTP method and requires access.

Initialize / Drop OTP List

You can use this action to register, remove, display and download user OTP Lists.

Unblock Account

You can use this action to unblock an account after max authentication attempts has been reached.

Import PSKC File

You can use the action to import a PSKC (RFC-6030) Token key file.

Export PSKC File

You can use the action to export the registered Token to a PSKC (RFC-6030) file.

Test User Login

You can use this action to test user authentication (Token, SMS, Mail, List) with OpenOTP.

Figure 6: OTP Authentication server

```
port="3306"
user="webadm"
password="password"
database="webadm"
```

```
/>
```



Note: For testing purposes, I have configured OpenLDAP without encryption. In a production environment, it's recommended that you should use TLS—in that case, the port would be 636, and the encryption would be "TLS".

Now we come to WebADM's main configuration file, `webadm.conf`. Most of the settings work out-of-the-box with any supported LDAP back-end, and with very minor changes. The file itself is very well documented so please read the comments before making changes. We need to change the LDAP tree base (suffix) in the following settings (adapting the domain name to your domain):

```
auth_mode DN
list_domain yes
proxy_user "cn=webadm,dc=example,dc=com"
proxy_password "testing123"
super_admins "cn=admin,dc=example,dc=com"
optionsets_container "dc=OptionSets,dc=example,dc=com"
webapps_container "dc=WebApps,dc=example,dc=com"
websrvs_container "dc=WebSrvs,dc=example,dc=com"
```